

MÉMOIRE DE VALIDATION ENTREPRISE - 2e ANNÉE

PRO-ENT5 - Étape 3

Critique et analyse

Sécuriser sans bloquer l'exploitation

Comment la sécurisation des pratiques d'administration systèmes et réseaux permet-elle de réduire les risques liés aux accès sensibles tout en maintenant une exploitation efficace du système d'information ?

Nom / Prénom	Thomas Teixeira
Entreprise	Viaposte
Poste	Administrateur systèmes et réseaux
Formation	Cycle Ingénieur - Cybersécurité et Systèmes
Année académique	2025 / 2026

Document pédagogique - données techniques anonymisées

Sommaire

Introduction	2
1. Cadre et méthode d'analyse	3
1.1. Périmètre et corpus de preuves	3
1.2. Grille d'analyse retenue	5
2. Analyse critique autour de la problématique	7
2.1. Maîtrise des identités et des privilèges	7
2.1.1. Une réduction concrète de la surface de risque	7
2.1.2. Les limites d'une approche centrée sur l'outil	8
2.1.3. Le compromis retenu	9
2.2. Préproduction, standardisation et journalisation	9
2.2.1. La validation préalable comme réduction du risque de changement ...	9
2.2.2. Standardiser sans figer	10
2.2.3. La centralisation des journaux : visibilité et preuve	11
2.2.4. Le risque de bruit et de dépendance	12
2.3. Interventions réseau, supervision et documentation	12
2.3.1. La préparation comme contrôle de sécurité	12
2.3.2. La documentation comme mémoire opérationnelle	13
2.3.3. La supervision comme boucle de vérification	14
2.4. Tensions transverses et effets de bord	14
2.4.1. Sécurité et rapidité d'intervention	14
2.4.2. Automatisation et maîtrise humaine	15
2.4.3. Complexité et capacité de maintien	15
2.5. Confrontation des approches	16
3. Position argumentée	17
3.1. Réponse à la problématique	17
3.2. Modèle opérationnel proposé	17
3.3. Conditions de mesure et de pérennité	18
4. Analyse réflexive de l'expérience professionnelle	20
4.1. Retour critique sur mon exécution	20
4.2. Ce que je referais différemment	21
4.3. Apports professionnels et personnels	22
4.3.1. Savoir-faire	22
4.3.2. Savoir-être	23
4.4. Limites de mon intervention	23
4.5. Plan de progression	24
5. Conclusion analytique	25
Bibliographie	27

Note de confidentialité

Le document conserve la logique des missions et les éléments nécessaires à l'analyse, mais ne reproduit aucun nom de serveur, compte, adresse, site précis, schéma détaillé ou paramètre susceptible d'identifier l'infrastructure. Les résultats sont présentés sous une forme agrégée ou généralisée. Cette démarche protège les informations internes sans supprimer les preuves utiles à l'évaluation.

Introduction

L'administration des systèmes et des réseaux repose sur un paradoxe. Pour maintenir les services, corriger un incident ou faire évoluer une infrastructure, les administrateurs doivent disposer de droits élevés et d'outils puissants. Ces moyens sont indispensables à l'exploitation, mais ils concentrent aussi le risque : une erreur, un compte compromis ou une action insuffisamment tracée peut avoir des conséquences beaucoup plus larges que dans un usage standard.

Chez Viaposte, cette question prend une importance particulière car le système d'information soutient des activités réparties sur plusieurs sites et soumises à des exigences fortes de disponibilité. La sécurité ne peut donc pas être ajoutée après coup, ni être conçue comme une succession de blocages. Elle doit être intégrée aux gestes quotidiens de l'administration tout en laissant aux équipes la capacité d'intervenir dans des délais compatibles avec la continuité de service.

La problématique retenue est la suivante : comment la sécurisation des pratiques d'administration systèmes et réseaux permet-elle de réduire les risques liés aux accès sensibles tout en maintenant une exploitation efficace du système d'information ? Cette question ne porte pas uniquement sur un produit ou une technologie. Elle interroge la manière de travailler : séparation des usages, maîtrise des habilitations, préparation des changements, standardisation, centralisation des journaux, supervision, documentation et coordination entre les acteurs.

Les étapes précédentes ont permis de sélectionner trois missions complémentaires. La première concerne l'administration et la sécurisation d'Active Directory. La deuxième porte sur la préparation d'environnements virtualisés, la création de templates Windows Server et la centralisation des événements avec Windows Event Collector. La troisième étudie les interventions réseau multi-sites, les contrôles de mise en service, la supervision et la documentation. Ces missions ont été retenues parce

qu'elles fournissent des preuves différentes d'un même phénomène : le risque diminue lorsque l'action d'administration devient explicite, limitée, vérifiable et transmissible.

L'objectif de cette étape est de dépasser le récit technique. Les constats du terrain sont confrontés à des recommandations externes et à leurs limites d'application. Le raisonnement suit le principe demandé dans le guide pédagogique : une idée forte doit être appuyée par une preuve professionnelle, une mise en perspective externe et un impact identifié. La position défendue est qu'une administration sécurisée repose sur un socle obligatoire de contrôle, mais que l'intensité des mesures doit rester proportionnée à la criticité des ressources et aux contraintes d'exploitation.¹

Thèse défendue

La sécurisation réduit durablement le risque lorsqu'elle combine moindre privilège, séparation des usages, validation des changements, traçabilité, supervision et documentation. Elle reste compatible avec l'exploitation à condition de prévoir des procédures simples pour les opérations courantes et des exceptions temporaires, justifiées et intégralement tracées pour les situations urgentes.

1. Cadre et méthode d'analyse

1.1. Périmètre et corpus de preuves

L'analyse s'appuie d'abord sur les livrables produits aux étapes 0, 1 et 2. Ils fixent la problématique, le contexte professionnel et les trois missions retenues. Elle s'appuie ensuite sur le rapport d'activités, qui contient les traces détaillées autorisées : captures d'outils, exports PowerShell anonymisés, procédures de templates et de collecte WEC, courriels de suivi, minutiers et comptes rendus d'intervention. Enfin, elle mobilise des publications de référence de l'ANSSI, du NIST et de Microsoft.

¹ ETNA, How-to Étape 3 : Critique et analyse, version 2026.02.23, méthode « idée forte = preuve terrain + mise en perspective externe + impact ».

Les preuves n'ont pas toutes la même nature. Les missions Active Directory disposent d'exports, de tableaux de bord et de rapports d'audit. Les travaux de virtualisation et de journalisation reposent sur des configurations, des abonnements, des procédures et des tests. Les interventions réseau s'appuient sur un minutier, une succession de contrôles et un compte rendu. Cette diversité ne permet pas de calculer un indicateur unique de réduction du risque, mais elle permet de comparer la solidité du processus et la capacité à démontrer le résultat.

Une distinction est maintenue entre constat et interprétation. Par exemple, l'apparition d'un même compte de service sur plusieurs hôtes est un fait issu d'un export. Le risque de propagation plus large en cas de compromission est une interprétation fondée sur le périmètre observé. De même, la présence d'un template documenté est vérifiable ; l'idée qu'il réduit la variabilité des déploiements constitue une interprétation raisonnable, mais qui devrait idéalement être mesurée sur plusieurs créations de serveurs.

Mission	Faits observables	Apport démontré	Limite principale
Active Directory	Création d'un premier lot de comptes d'infrastructure nominatifs ; exports PowerShell ; analyse d'un compte de service présent sur plusieurs hôtes ; suivi d'audit toutes les deux semaines.	Meilleure séparation des usages, traçabilité plus lisible et priorisation collective des écarts.	Les outils signalent des écarts sans connaître toutes les dépendances métier ou techniques.
Préproduction et journalisation	Templates Windows Server 2022 et 2025 ; environnement de préproduction ; procédures de template et WEC ; collecte centralisée sur un périmètre autorisé.	Déploiements plus homogènes, validation en amont et accès centralisé aux événements.	Écart entre préproduction et production ; obsolescence des templates ; volume de journaux à maîtriser.
Réseau et supervision	Minutier ; identification préalable du matériel ; tests progressifs du lien, de l'adressage et du VLAN ; suivi Centreon ; compte rendu.	Réduction de l'improvisation, localisation plus rapide d'un écart et transmission de l'état final.	Les contraintes physiques et la documentation ancienne peuvent invalider le scénario prévu.

Ces éléments sont détaillés dans l'étape 2 et dans le rapport d'activités. Ils servent ici de matériau analytique, et non de prétexte à répéter le déroulement des missions.²

1.2. Grille d'analyse retenue

Le cadre d'analyse repose sur cinq critères. Le premier est la réduction de l'exposition : un compte, un poste ou un chemin d'administration doit être limité au périmètre réellement nécessaire. Le deuxième est la traçabilité : une action sensible doit pouvoir être reliée à une identité, un moment, un objectif et un résultat. Le troisième est la réversibilité : un changement doit prévoir des critères d'arrêt et, lorsque cela est possible, une méthode de retour arrière. Le quatrième est l'exploitabilité : la mesure de sécurité doit pouvoir être appliquée dans les conditions réelles du service. Le cinquième est la pérennité : les contrôles, documents et outils doivent rester maintenus dans le temps.

Le principe du moindre privilège constitue le point de départ. Le NIST le définit comme la restriction des droits au minimum nécessaire à l'exécution d'une tâche. Dans un environnement d'administration, ce principe ne signifie pas l'absence de privilèges : il impose de justifier leur niveau, leur durée, leur contexte d'utilisation et leur réévaluation.³

Les recommandations de l'ANSSI complètent cette approche par la séparation des flux d'administration, le cloisonnement des ressources sensibles, la maîtrise des postes et des comptes utilisés ainsi que la disponibilité d'une documentation fidèle à l'état du système. Pour les environnements Active Directory, l'ANSSI insiste aussi sur le découpage en

² TEIXEIRA T., PRO-ENT5 - Étape 2 : Missions et projets en lien avec la problématique, 2026 ; Rapport d'activités d'alternance, Viaposte, 2025-2026, parties consacrées à Active Directory, vSphere, WEC et aux interventions sur site.

³ NIST, Least Privilege, Computer Security Resource Center Glossary : limitation des droits au minimum nécessaire à l'exécution d'une tâche.

zones de confiance et la protection des chemins qui permettent d'atteindre les composants les plus critiques.⁴⁵

La gestion sécurisée des changements apporte une troisième perspective. Le NIST recommande de documenter, tester, approuver et vérifier les modifications afin de maintenir l'intégrité des configurations. Cette logique permet de relier les missions de préproduction et d'intervention réseau à la problématique des accès sensibles : le risque ne vient pas seulement de l'identité qui agit, mais aussi de la manière dont l'action est préparée et contrôlée.⁶

Hypothèse de travail

Plus une action d'administration est limitée, préparée, vérifiable et réversible, plus le risque d'erreur ou de compromission diminue. Toutefois, le bénéfice se dégrade lorsque les contrôles ajoutent une complexité disproportionnée, produisent du bruit ou ne prévoient aucun mode d'intervention urgent.

2. Analyse critique autour de la problématique

2.1. Maîtrise des identités et des privilèges

2.1.1. Une réduction concrète de la surface de risque

Active Directory concentre une part importante des identités, des groupes et des habilitations. Un compte disposant de droits élevés peut modifier des configurations, ajouter d'autres privilèges ou accéder à des ressources sensibles. La sécurisation de l'annuaire constitue donc un levier

⁴ ANSSI, Recommandations relatives à l'administration sécurisée des systèmes d'information reposant sur Microsoft Active Directory, guide ANSSI-PA-099, version 1.0, octobre 2023.

⁵ ANSSI, Recommandations relatives à l'administration sécurisée des systèmes d'information, guide ANSSI-PA-022, version 3.0, mai 2021.

⁶ JOHNSON A. et al., Guide for Security-Focused Configuration Management of Information Systems, NIST SP 800-128, 2011, mise à jour 2019.

prioritaire, car une faiblesse sur un chemin d'administration peut produire un impact étendu.

Le premier apport observé est la séparation des usages. Un premier lot de comptes d'infrastructure nominatifs a été créé pour certaines solutions techniques qui ne pouvaient pas utiliser le compte d'administration habituel. L'objectif n'était pas d'ajouter des identités sans contrôle, mais de distinguer une fonction technique précise d'un usage administratif plus général. Les actions deviennent ainsi plus faciles à interpréter dans les journaux et l'exposition d'un même secret dans plusieurs contextes diminue.⁷

Le deuxième apport est l'objectivation des droits. PowerShell a permis d'extraire les propriétés de comptes et de groupes, puis de les traiter sous forme de tableaux. Une analyse a fait apparaître qu'un même compte de service était utilisé sur plusieurs hôtes. Le fait observé ne prouve pas une compromission, mais il révèle un périmètre d'usage large. La conséquence potentielle est claire : si ce compte est compromis, l'attaquant dispose de davantage de points d'appui. Le contrôle devient donc plus pertinent lorsqu'il conduit à restreindre les usages légitimes, à documenter les dépendances et à renforcer la surveillance.

Le troisième apport est la mise en commun de la décision. Les rapports PingCastle et les outils de reporting Active Directory ont fourni une vue structurée des écarts, des chemins de contrôle et des événements inhabituels. Des réunions organisées toutes les deux semaines permettaient de qualifier les constats, de répartir les corrections et de suivre les points ouverts. Ce fonctionnement évite qu'un score d'audit soit traité comme une vérité automatique : l'outil alimente la discussion, mais la décision reste collective.

⁷ TEIXEIRA T., Rapport d'activités d'alternance, Viaposte, 2025-2026, pp. 24-30 : création des comptes d'infrastructure, exports PowerShell et analyses Active Directory.

Preuve terrain et impact

Fait : des comptes dédiés, des exports et un suivi bimensuel ont été mis en place. Impact : la lecture des usages sensibles est devenue plus précise et les écarts peuvent être priorisés. Limite : aucune série historique ne permet encore d'attribuer un pourcentage chiffré de réduction des incidents à ces mesures.

2.1.2. Les limites d'une approche centrée sur l'outil

Un outil d'audit ne connaît pas toujours la justification d'un droit. Une délégation peut être ancienne mais encore nécessaire à une application ; un compte peut apparaître sur plusieurs machines parce qu'un service dépend réellement de ce périmètre. Supprimer un accès uniquement pour faire disparaître une alerte peut provoquer une indisponibilité. La qualité de la remédiation dépend donc de la connaissance des dépendances, de la validation par les responsables concernés et de la possibilité de revenir en arrière.

À l'inverse, un score satisfaisant ne garantit pas une administration sécurisée. Des faiblesses organisationnelles peuvent persister : absence de revue périodique, documentation incomplète, mauvaise séparation entre les usages courants et privilégiés, ou conservation d'exceptions sans date de fin. La sécurité des identités ne peut pas être réduite à un tableau de bord ; elle nécessite une gouvernance des comptes, des propriétaires identifiés et des contrôles répétés.

Deux approches se confrontent alors. La première cherche à corriger le plus grand nombre d'écarts possible. La seconde priorise selon le risque : niveau de privilège, exposition, criticité de la ressource et impact d'une modification. La deuxième approche est plus lente au départ, mais elle produit des décisions plus durables et limite les contournements. Elle correspond également à la stratégie Microsoft de réduction progressive des

chemins d'accès privilégiés, qui vise à ne conserver qu'un nombre limité de voies autorisées, protégées et surveillées.⁸

2.1.3. Le compromis retenu

La séparation des comptes est pertinente lorsqu'elle répond à un usage clair, lorsque l'identité reste nominative et lorsque son périmètre est documenté. Elle devient contre-productive si elle multiplie les secrets sans règles, si les administrateurs ne savent plus quel compte employer ou si les droits ne sont jamais réévalués.

Le compromis consiste donc à maintenir des comptes distincts pour les fonctions sensibles, à limiter les droits permanents et à prévoir des mécanismes temporaires pour les besoins exceptionnels. L'accès urgent doit rester possible, mais il doit être attribué à une personne, limité dans le temps, justifié, journalisé et revu après l'intervention. Cette logique réduit le sur-privilege sans retirer la capacité d'agir.

2.2. Préproduction, standardisation et journalisation

2.2.1. La validation préalable comme réduction du risque de changement

La mise en production d'un serveur ou d'une solution crée un risque lorsque la configuration est réalisée directement sur un environnement opérationnel. La préproduction permet de vérifier l'installation, les dépendances, les flux et les paramètres avant d'exposer les utilisateurs. Elle transforme une hypothèse technique en résultat observable et fournit un support de discussion pour l'équipe.

Dans les missions étudiées, un environnement isolé a été utilisé pour tester une solution de transfert de fichiers sécurisée avant une éventuelle mise en production. Le résultat ne se limite pas à la présence d'une machine de test : il réside dans la possibilité de détecter une incompatibilité ou un paramètre insuffisamment maîtrisé sans affecter le service existant. Cette

⁸ MICROSOFT, Developing a privileged access strategy, Microsoft Learn, mise à jour juin 2024.

approche rejoint la gestion sécurisée des configurations recommandée par le NIST, fondée sur la proposition, la justification, le test, l'approbation et la vérification du changement.⁹

La création de templates Windows Server 2022 et 2025 a poursuivi le même objectif. Un modèle maintenu réduit la répétition des réglages manuels et fournit un socle commun. Il facilite aussi le diagnostic : deux serveurs issus du même template peuvent être comparés plus facilement. La procédure dédiée, notamment sur le contrôleur PVSCSI, rend le déploiement reproductible et transmet les choix à l'équipe.¹⁰

2.2.2. Standardiser sans figer

La standardisation apporte de la vitesse et de la cohérence, mais elle comporte un risque de dérive. Un template devient obsolète si les correctifs, versions ou standards de sécurité évoluent sans qu'il soit mis à jour. Un modèle ancien peut alors reproduire rapidement une faiblesse sur plusieurs serveurs. La standardisation ne réduit le risque que si elle s'accompagne d'un propriétaire, d'une date de revue et d'un processus de maintenance.

Elle ne doit pas non plus interdire toute adaptation. Certains rôles applicatifs ont des exigences particulières. Le bon modèle est donc un socle obligatoire contenant les paramètres communs, complété par des exceptions documentées. Chaque dérogation doit indiquer son motif, son impact, sa durée éventuelle et les contrôles compensatoires retenus. Cette approche conserve les bénéfices du template sans transformer la conformité en rigidité aveugle.

2.2.3. La centralisation des journaux : visibilité et preuve

Les événements d'authentification, de modification de comptes ou d'erreur de service perdent une grande partie de leur valeur lorsqu'ils restent

⁹ JOHNSON A. et al., Guide for Security-Focused Configuration Management of Information Systems, NIST SP 800-128, 2011, mise à jour 2019.

¹⁰ TEIXEIRA T., Rapport d'activités d'alternance, Viaposte, 2025-2026, partie « Création de serveur sur vSphere » et annexe « Template-2025-PVSCSI », pp. 31 et 38-44.

dispersés sur les machines. Windows Event Collector et Windows Event Forwarding permettent de recevoir sur un collecteur des événements sélectionnés provenant de sources autorisées. Dans la mission étudiée, une stratégie de groupe indiquait le collecteur tandis que l'abonnement limitait le périmètre effectif d'envoi. Le choix évitait de confondre une configuration largement distribuée avec une collecte sans contrôle.¹¹

Le résultat observable est l'existence d'un point commun de consultation et d'une procédure décrivant l'architecture, l'abonnement et la configuration. La centralisation améliore la capacité à rechercher un événement et à conserver une trace au-delà du poste d'origine. Elle contribue donc à l'exploitation autant qu'à la sécurité : un diagnostic peut commencer depuis une source commune au lieu de dépendre d'un accès successif à chaque machine.

L'ANSSI rappelle toutefois que la journalisation est nécessaire mais insuffisante. Les événements doivent être protégés, conservés selon une durée adaptée et exploités par des règles ou des personnes capables d'identifier les scénarios pertinents. La documentation Microsoft sur WEF distingue également une collecte de base et une collecte renforcée pour les machines suspectes, ce qui illustre l'intérêt d'un niveau de détail proportionné au contexte.¹²¹³

¹¹ TEIXEIRA T., PRO-ENT5 - Étape 2, mission 2 ; Rapport d'activités, annexe « Windows Event Collector », pp. 45-56.

¹² MICROSOFT, Use Windows Event Forwarding to assist in intrusion detection, Microsoft Learn, mise à jour août 2025.

¹³ ANSSI, Recommandations de sécurité pour l'architecture d'un système de journalisation, guide ANSSI-PA-012, version 2.0, janvier 2022.

Observation et interprétation

Observation : les événements d'un périmètre autorisé sont centralisés et la configuration est documentée. Interprétation : la recherche et l'investigation deviennent plus efficaces. Point de vigilance : la valeur réelle dépend de la sélection des événements, de la disponibilité du collecteur et de la capacité de l'équipe à analyser les données.

2.2.4. Le risque de bruit et de dépendance

Collecter davantage ne signifie pas détecter davantage. Un volume important augmente les besoins de stockage, ralentit les recherches et peut masquer les signaux importants. Une règle trop sensible génère des alertes répétitives ; une règle trop large ne détecte pas les comportements significatifs. La gouvernance des journaux doit donc préciser la finalité de chaque source, le responsable, la durée de conservation, le niveau de criticité et le mode d'exploitation.

La centralisation crée aussi une dépendance. Une panne du collecteur, une stratégie de groupe mal appliquée ou une rupture réseau peut interrompre la remontée. Cette limite ne justifie pas le retour à des journaux dispersés ; elle impose de superviser la chaîne de collecte, de vérifier régulièrement la présence d'événements attendus et de prévoir une capacité de reprise. La sécurité du dispositif dépend autant de sa disponibilité que de sa configuration initiale.

2.3. Interventions réseau, supervision et documentation**2.3.1. La préparation comme contrôle de sécurité**

Les interventions réseau montrent que le risque ne se limite pas aux comptes. Une erreur de port, de fibre, d'adressage ou de VLAN peut interrompre un service. La préparation physique, le repérage des équipements, le minutier et l'ordre des contrôles constituent donc des mesures de sécurité opérationnelle.

Lors d'une intervention sur un site logistique, le chemin de raccordement entre plusieurs baies a été préparé et documenté. Des équipements

intermédiaires et un commutateur local ont été installés, puis la connectivité a été vérifiée progressivement. L'équipement final n'a été considéré comme opérationnel qu'après validation du lien physique, de l'adressage et de l'appartenance au VLAN attendu.¹⁴

Cette succession de contrôles réduit l'incertitude. Lorsqu'une étape échoue, le point de rupture est plus facile à localiser. Le minutier facilite également la coordination avec les personnes présentes et évite les improvisations pendant la fenêtre d'intervention. La sécurité améliore ici directement l'efficacité : les étapes de vérification demandent du temps, mais elles réduisent le temps perdu à rechercher une anomalie non localisée.

2.3.2. La documentation comme mémoire opérationnelle

Le compte rendu et les schémas permettent à une autre personne de comprendre ce qui a été réalisé. Ils réduisent la dépendance à la mémoire de l'intervenant et servent de référence lors d'un incident ultérieur. L'ANSSI recommande que les administrateurs disposent d'une documentation reflétant fidèlement l'état courant du système, notamment les cartographies physiques, systèmes, réseau et applicatives.¹⁵

Cette exigence comporte néanmoins une difficulté : une documentation non mise à jour peut être plus dangereuse qu'une absence de document, car elle donne une confiance injustifiée. Lorsqu'un schéma ne correspond plus au terrain, l'administrateur peut préparer une intervention sur une hypothèse fautive. Le document doit donc avoir un propriétaire, une date de revue et un lien avec le processus de changement.

Un bon runbook ne doit pas être une simple liste de commandes. Il doit préciser l'objectif, les prérequis, les dépendances, les critères de réussite, les

¹⁴ TEIXEIRA T., PRO-ENT5 - Étape 2, mission 3 ; Rapport d'activités, annexe « Intervention sur site », pp. 57-64.

¹⁵ ANSSI, Recommandations relatives à l'administration sécurisée des systèmes d'information, guide ANSSI-PA-022, version 3.0, mai 2021.

éléments de preuve, le point d'arrêt et la méthode d'escalade. Il guide l'action sans supprimer le jugement professionnel. Dans un incident atypique, l'administrateur doit conserver la capacité de vérifier les hypothèses et d'adapter l'ordre des opérations.

2.3.3. La supervision comme boucle de vérification

La supervision complète la préparation. Avant le changement, elle fournit un état de référence. Pendant l'intervention, elle permet d'observer les effets. Après la mise en service, elle confirme que les équipements et services restent disponibles. Sans cette boucle, une opération peut être déclarée réussie parce que les commandes ont été exécutées alors qu'un service secondaire est dégradé.

Centreon a été utilisé pour détecter les indisponibilités et déclencher une prise de contact avec le site lorsque la résolution à distance n'était pas suffisante. L'outil apporte une visibilité continue, mais il ne donne pas toujours la cause racine. L'alerte doit donc être reliée à une responsabilité, à une procédure de qualification et à un niveau de priorité. Comme pour les journaux, l'enjeu n'est pas de produire le maximum de signaux, mais de disposer d'informations actionnables.

2.4. Tensions transverses et effets de bord

2.4.1. Sécurité et rapidité d'intervention

Chaque contrôle ajoute une étape : changement de compte, validation, test, journalisation ou compte rendu. Ces contraintes sont justifiées lorsqu'elles protègent une ressource critique, mais elles peuvent ralentir une opération simple ou urgente. Une chaîne de validation trop longue peut prolonger une indisponibilité ; un mécanisme d'accès temporaire trop lent peut encourager la conservation de privilèges permanents.

La réponse ne consiste pas à supprimer les contrôles, mais à les adapter. Les actifs critiques exigent des validations fortes et des chemins d'administration protégés. Les opérations courantes à faible risque peuvent suivre un processus simplifié, à condition de rester tracées. Les situations

d'urgence doivent disposer d'un mode dégradé documenté, avec une revue a posteriori obligatoire.

2.4.2. Automatisation et maîtrise humaine

PowerShell, les templates, WEC et la supervision améliorent la vitesse et la répétabilité. Toutefois, une automatisation peut propager une erreur plus rapidement qu'une action manuelle. Elle doit donc intégrer des contrôles d'entrée, une gestion des erreurs, un journal d'exécution et, pour les actions sensibles, une validation explicite.

L'automatisation est pertinente pour les tâches répétitives et vérifiables. Elle ne remplace pas l'analyse lorsque le contexte est ambigu. L'objectif n'est pas de retirer l'humain de la décision, mais de lui fournir des données plus fiables et de réduire les manipulations sans valeur ajoutée.

2.4.3. Complexité et capacité de maintien

Une architecture d'administration sécurisée peut elle-même devenir complexe : comptes dédiés, postes protégés, collecteurs, outils d'audit, abonnements, règles de supervision et procédures d'urgence. Chaque composant ajoute une dépendance à maintenir. Une solution excellente sur le papier devient fragile si l'équipe ne dispose pas du temps, des compétences ou des responsabilités nécessaires pour la faire vivre.

L'approche proportionnée ne signifie donc pas accepter une sécurité faible. Elle consiste à prioriser les identités, composants et chemins dont la compromission aurait l'impact le plus large, puis à étendre progressivement les mesures. Cette séquence produit des résultats visibles et permet d'ajuster l'organisation avant une généralisation.

2.5. Confrontation des approches

Les missions permettent de comparer trois modèles. Le premier privilégie la rapidité avec des droits larges et peu de formalisme. Le deuxième applique des restrictions uniformes et un contrôle maximal. Le troisième adapte les mesures à la criticité tout en maintenant un socle

commun. Aucun modèle n'est neutre : chacun crée des bénéfices et des risques différents.

Approche	Bénéfices	Limites	Conditions de validité
Priorité à l'exploitation	Interventions rapides ; faible coût initial ; autonomie immédiate.	Sur-privège ; faible traçabilité ; dépendance aux personnes ; impact élevé d'une compromission.	Uniquement pour des opérations peu sensibles et avec des contrôles compensatoires explicites.
Restriction uniforme	Séparation forte ; réduction des chemins d'accès ; contrôle renforcé.	Complexité ; délais ; risque de contournement ; dépendance aux outils de sécurité.	Adaptée aux actifs les plus critiques si les moyens d'exploitation et d'urgence sont disponibles.
Approche proportionnée	Priorisation ; compatibilité avec l'exploitation ; amélioration progressive ; exceptions contrôlées.	Exige une bonne connaissance du SI, des arbitrages et des revues régulières.	Socle obligatoire, contrôles renforcés selon la criticité, responsabilités et indicateurs définis.

La sécurité la plus forte sur le papier n'est pas toujours la plus efficace dans la durée. Une architecture ne protège réellement que si elle peut être comprise, maintenue et utilisée, y compris lors d'un incident. À l'inverse, la recherche de simplicité ne justifie ni les privilèges permanents ni l'absence de preuve. L'approche proportionnée est plus exigeante sur le plan de l'analyse, mais elle est la seule à articuler durablement protection et exploitation.

3. Position argumentée

3.1. Réponse à la problématique

Position finale

La sécurisation des pratiques d'administration réduit les risques liés aux accès sensibles lorsqu'elle combine moindre privilège, séparation des usages, cloisonnement, validation des changements, journalisation, supervision et documentation. Elle maintient une exploitation efficace lorsque les contrôles sont proportionnés à la criticité, automatisés lorsqu'ils sont répétitifs et complétés par des exceptions temporaires, justifiées, limitées et revues.

Cette réponse refuse l'opposition simpliste entre sécurité et efficacité. Les missions montrent que plusieurs mesures de sécurité améliorent directement le travail. Les exports PowerShell accélèrent la revue des droits. Les comptes dédiés rendent les actions plus lisibles. Les templates réduisent les écarts entre serveurs. La préproduction diminue les corrections urgentes. WEC facilite l'accès aux traces. Le minutier et les tests progressifs rendent les interventions plus prévisibles.

Le bénéfice dépend toutefois du dimensionnement. Une procédure de changement est utile lorsqu'elle aide à décider, à vérifier et à revenir en arrière ; elle devient un obstacle si elle accumule des validations sans valeur ajoutée. Une collecte de journaux améliore l'investigation lorsqu'elle est reliée à des scénarios et à des responsabilités ; elle devient une dette lorsqu'elle produit des données inexploitées. Un compte dédié réduit l'exposition lorsqu'il correspond à un usage précis ; il ajoute de la complexité lorsqu'il n'est ni documenté ni réévalué.

3.2. Modèle opérationnel proposé

Le modèle proposé repose sur cinq niveaux complémentaires.

1. Identités - Séparer les usages courants et administratifs ; maintenir des comptes nominatifs ; réévaluer les groupes sensibles ; limiter les privilèges permanents.

2. Chemins d'administration - Utiliser des postes, flux et interfaces protégés pour les ressources critiques ; limiter les points d'entrée autorisés.

3. Changements - Préparer, tester, approuver, surveiller et documenter les modifications ; prévoir des critères d'arrêt et un retour arrière.

4. Traçabilité - Centraliser les événements significatifs ; protéger leur intégrité ; vérifier la chaîne de collecte ; relier les alertes à une procédure.

5. Gouvernance - Attribuer un propriétaire aux comptes, templates, abonnements, documents et indicateurs ; organiser des revues régulières.

À ce socle s'ajoute une procédure d'exception. Une intervention urgente peut nécessiter un accès plus large ou un processus accéléré. L'exception doit être limitée dans le temps, associée à une personne, justifiée par une situation, journalisée et clôturée. Une revue a posteriori vérifie sa légitimité et permet de transformer l'expérience en amélioration du processus.

Niveau de criticité	Contrôles attendus	Mode d'exception
Critique	Compte dédié, chemin protégé, validation formelle, journalisation renforcée, supervision et revue périodique.	Accès d'urgence nominatif, durée courte, approbation ou justification a posteriori immédiate.
Important	Moindre privilège, changement testé, journalisation du socle, documentation et contrôle post-déploiement.	Procédure accélérée avec traçabilité et clôture obligatoire.
Courant	Droits adaptés, automatisation validée, preuve d'exécution et procédure simplifiée.	Escalade vers le niveau supérieur si le périmètre ou l'impact évolue.

3.3. Conditions de mesure et de pérennité

Une démarche mature ne se contente pas d'installer des outils. Elle mesure la couverture, l'usage réel et la maintenance. Les indicateurs ne prouvent pas seuls la sécurité, mais ils permettent d'observer l'évolution, d'identifier les écarts et de prioriser les efforts.

- Part des comptes et groupes sensibles disposant d'un propriétaire, d'une justification et d'une date de revue.
- Nombre de constats d'audit qualifiés, corrigés, acceptés ou restant ouverts, avec leur niveau de criticité.

- Part des serveurs déployés à partir d'un template maintenu et date de dernière validation du modèle.
- Couverture des sources WEC prioritaires, présence d'événements tests et délai moyen de recherche lors d'une investigation.
- Part des changements sensibles disposant d'un test, d'un critère de réussite, d'un retour arrière et d'un contrôle post-déploiement.
- Part des documents critiques avec propriétaire et date de revue ; nombre d'écarts entre documentation et terrain.
- Nombre d'exceptions d'accès ouvertes, durée moyenne et taux de clôture après revue.

Ces indicateurs doivent être peu nombreux, stables et reliés à une décision. Mesurer uniquement le nombre d'alertes ou le volume de journaux encouragerait une logique quantitative sans valeur. L'objectif est d'identifier si les pratiques réduisent réellement l'exposition, améliorent la preuve et maintiennent la capacité d'intervention.

4. Analyse réflexive de l'expérience professionnelle

4.1. Retour critique sur mon exécution

Au début de mon évolution vers l'administration systèmes et réseaux, mon attention était surtout concentrée sur l'obtention du résultat technique : créer le compte, déployer le serveur, appliquer la configuration ou rétablir la connectivité. Avec l'expérience, j'ai progressivement ajouté d'autres questions : le résultat est-il vérifiable ? Les droits utilisés sont-ils proportionnés ? Une autre personne peut-elle comprendre l'action ? Existe-t-il un retour arrière ? La procédure restera-t-elle valable après une évolution ?

Cette progression est visible dans les missions Active Directory. Une extraction PowerShell n'a de valeur que si les attributs sont choisis correctement, si le traitement est compréhensible et si le constat conduit à une décision. De la même manière, un rapport PingCastle ne constitue pas une remédiation. Il faut qualifier le chemin de risque, identifier les dépendances et suivre l'action dans le temps. J'ai appris à ne plus confondre la production d'un résultat avec la résolution du problème.

Les travaux de préproduction et de journalisation ont renforcé cette logique de preuve. Une première approche aurait pu considérer la machine créée ou le service WEC activé comme un résultat suffisant. La démarche complète exige de vérifier le périmètre, la réception des événements, les droits, la stabilité et la reproductibilité par la procédure. Cette évolution traduit le passage d'une logique d'exécution à une logique de contrôle.

Sur les interventions réseau, j'ai également appris à mieux préparer la communication. Une opération techniquement claire pour l'administrateur peut rester difficile à suivre pour l'exploitation ou les personnes présentes sur site. Le minutier, les points de contrôle et le compte rendu créent un cadre commun. La communication n'est donc pas extérieure à la technique ; elle contribue directement à la réduction du risque.

La principale faiblesse de mon exécution concerne la mesure. Plusieurs bénéfices sont réels mais restent qualitatifs, car les indicateurs n'étaient pas toujours définis avant l'action. Une meilleure visibilité sur les comptes sensibles est utile, mais elle serait plus démonstrative avec un inventaire initial, une classification des écarts et un suivi régulier des corrections. Cette limite méthodologique constitue mon premier axe de progression.

4.2. Ce que je referais différemment

Si ces missions devaient être reprises, je commencerais par formaliser une situation de référence. Pour Active Directory, je définirais le périmètre des comptes et groupes sensibles, les critères de criticité, les propriétaires et la fréquence de revue. Pour la journalisation, je construirais une matrice des sources, événements, usages, durées et responsables. Pour les interventions réseau, l'état de référence comprendrait la cartographie, les versions, les dépendances et les contrôles de disponibilité.

Je séparerais également plus clairement les phases d'exploration et d'exploitation. Un premier script ou une procédure provisoire peut être utile pour comprendre le besoin, mais son passage en usage durable doit inclure une revue, une gestion des erreurs, des journaux d'exécution, une documentation et une validation. Cette étape éviterait qu'un outil temporaire devienne critique sans avoir été suffisamment sécurisé.

Une troisième amélioration concernerait l'accompagnement des utilisateurs techniques. Lorsqu'un compte dédié, une restriction ou une nouvelle procédure est mis en place, il est nécessaire d'expliquer le risque traité, le fonctionnement normal et le mode d'urgence. Une mesure comprise est mieux appliquée et produit des retours plus utiles. Je prévois donc un test avec les personnes concernées avant la généralisation.

Enfin, j'organiserais systématiquement une revue après intervention. Elle ne devrait pas seulement confirmer la réussite, mais comparer le plan à la réalité, identifier les étapes inutiles, les informations manquantes et les risques apparus. Les enseignements seraient ensuite intégrés au template,

au script, au runbook ou à la cartographie. Cette boucle d'amélioration continue empêcherait que chaque opération reste un cas isolé.

4.3. Apports professionnels et personnels

4.3.1. Savoir-faire

Ces missions ont renforcé ma compréhension de la gestion des identités et des privilèges. L'administration d'un annuaire ne se limite pas à créer des comptes ou à ajouter des membres dans des groupes. Elle implique de comprendre les délégations, les dépendances, la traçabilité et les conséquences d'un droit trop large. PowerShell m'a permis de traiter les informations de manière plus structurée et de produire des contrôles reproductibles.

Les travaux de virtualisation et de journalisation ont développé ma capacité à concevoir une chaîne complète : création de l'environnement, configuration, test, collecte, vérification et restitution. J'ai appris à distinguer la disponibilité d'une donnée de son exploitabilité. Un événement n'a de valeur que s'il est fiable, horodaté, protégé, accessible aux personnes autorisées et interprétable dans un délai compatible avec l'incident.

Les interventions sur l'infrastructure ont renforcé mes compétences en préparation de changement, coordination et diagnostic. Elles m'ont appris à identifier les points de contrôle et à ne pas considérer une configuration comme réussie avant la validation de l'état global. La rédaction de comptes rendus et de procédures a également amélioré ma capacité à transmettre une information technique à des interlocuteurs différents.

4.3.2. Savoir-être

Sur le plan personnel, ces expériences ont renforcé ma rigueur. La manipulation d'accès sensibles ou d'équipements critiques impose de résister à la précipitation, même lorsque la demande est urgente. J'ai appris à vérifier les hypothèses, à relire les commandes, à conserver une trace et à demander une confirmation lorsqu'une information reste ambiguë.

Elles ont aussi développé ma capacité à reconnaître l'incertitude. Une erreur fréquente dans les métiers techniques consiste à présenter une solution comme certaine alors que plusieurs dépendances restent inconnues. Je distingue davantage ce qui est vérifié, ce qui est probable et ce qui doit encore être testé. Cette transparence améliore la confiance de l'équipe et facilite les décisions.

Enfin, j'ai appris à adapter le niveau de détail. Un administrateur a besoin des paramètres, flux et critères techniques. Un responsable attend surtout le risque, l'impact, la durée et la décision à prendre. Une personne sur site doit connaître l'ordre des manipulations et les contrôles. Cette capacité de communication fait désormais partie intégrante de mon rôle.

4.4. Limites de mon intervention

Mon apport à l'entreprise réside principalement dans l'amélioration de la visibilité, de la reproductibilité et de la documentation. Les analyses de comptes ont fourni des éléments objectifs pour discuter des habilitations. Les templates et procédures ont facilité la transmission. La centralisation des événements a amélioré l'accès aux traces. Les minutiers et comptes rendus ont rendu les interventions plus compréhensibles.

J'ai également développé une posture de proposition. Plutôt que de limiter mon rôle à l'exécution d'une demande, j'ai cherché à identifier les contrôles nécessaires, les risques, les vérifications et les améliorations possibles. Cette posture reste néanmoins encadrée par mon périmètre. Les choix d'architecture, de budget, de politique d'habilitation et d'outils de sécurité relèvent de plusieurs responsables et équipes.

Je ne pouvais donc pas transformer seul l'ensemble des pratiques. Une administration sécurisée est un système collectif qui demande une gouvernance, des responsabilités, des moyens et une continuité dans le temps. Mon rôle consiste à appliquer les règles, à signaler les écarts, à produire des preuves et à proposer des améliorations réalistes. Reconnaître cette limite évite d'enjoliver mon intervention et permet de situer clairement ma contribution.

4.5. Plan de progression

Les enseignements tirés de ces missions conduisent à un plan de progression centré sur la mesure, l'automatisation maîtrisée et la gouvernance. L'objectif n'est pas d'accumuler des outils, mais d'améliorer la capacité à démontrer l'efficacité des pratiques et à les maintenir.

Axe	Action prioritaire	Indicateur	Horizon
Privileges	Formaliser l'inventaire, le propriétaire et la justification des comptes et groupes sensibles.	Taux documenté ; fréquence de revue ; exceptions ouvertes.	Court terme
Journalisation	Définir une matrice des sources, événements, usages, durées et responsables.	Couverture prioritaire ; délai de recherche ; alertes qualifiées.	Court à moyen terme
Changements	Généraliser les critères d'entrée, de réussite, de retour arrière et de contrôle post-déploiement.	Part des changements testés ; incidents post-changement.	Moyen terme
Automatisation	Renforcer la gestion des erreurs, le contrôle des entrées, les journaux et la revue des scripts.	Scripts documentés et revus ; échecs détectés.	Moyen terme
Documentation	Attribuer un propriétaire et une date de revue aux documents critiques.	Documents revus ; écarts terrain/documentation.	Continu
Compétences	Approfondir le PAM, la détection, l'analyse de risque et la gestion d'incident.	Formations ; exercices ; retours d'expérience.	Continu

5. Conclusion analytique

L'analyse des trois missions montre que la sécurisation des pratiques d'administration peut réduire les risques liés aux accès sensibles sans dégrader l'exploitation, à condition d'être conçue comme une amélioration du travail et non comme une accumulation de contraintes. La maîtrise des habilitations limite l'exposition des comptes puissants. La séparation des usages rend les opérations plus lisibles. La préproduction et les templates réduisent l'incertitude. La centralisation des événements améliore la capacité à comprendre ce qui s'est produit. La documentation, les tests progressifs et la supervision rendent les interventions plus fiables et transmissibles.

Ces bénéfices ont des limites. Les outils d'audit ne remplacent pas la connaissance du contexte. La préproduction ne reproduit jamais totalement la production. Un template peut devenir obsolète. La journalisation peut produire du bruit et créer une dépendance au collecteur. Une procédure peut devenir trop rigide ou ne plus correspondre au terrain. Enfin, une architecture très sécurisée peut être difficile à maintenir si les responsabilités et les moyens ne sont pas définis.

La réponse à la problématique est donc la suivante : la sécurisation réduit durablement le risque lorsqu'elle repose sur un socle de moindre privilège, de séparation, de validation, de traçabilité, de supervision et de documentation, puis adapte l'intensité des contrôles à la criticité. Les exceptions opérationnelles doivent rester possibles, mais elles doivent être temporaires, justifiées, limitées et revues. Cet équilibre préserve la capacité d'intervention tout en réduisant les droits permanents et les actions non maîtrisées.

Cette étape met également en évidence mon évolution professionnelle. Mon rôle ne se limite plus à exécuter une opération technique. Il consiste à préparer, vérifier, documenter, communiquer et prendre position sur les risques. J'ai développé davantage d'autonomie, tout en comprenant mieux

la nécessité de la validation collective. J'ai aussi identifié une marge de progression dans la définition d'indicateurs et la mesure des résultats.

La poursuite de cette démarche doit conduire à une administration plus mesurable et progressive. L'enjeu sera d'automatiser les contrôles répétitifs sans perdre la capacité d'analyse, de mieux gérer les privilèges temporaires, de relier les journaux à des scénarios de détection et de maintenir la documentation comme un véritable référentiel d'exploitation. La sécurité deviendra alors non seulement une protection du système d'information, mais aussi un facteur de qualité, de continuité et de confiance.

Bibliographie

AGENCE NATIONALE DE LA SÉCURITÉ DES SYSTÈMES D'INFORMATION (ANSSI),

Recommandations relatives à l'administration sécurisée des systèmes d'information, guide ANSSI-PA-022, version 3.0, mai 2021.

<https://messervices.cyber.gouv.fr/guides/recommandations-relatives-ladministration-securisee-des-si>

AGENCE NATIONALE DE LA SÉCURITÉ DES SYSTÈMES D'INFORMATION (ANSSI),

Recommandations relatives à l'administration sécurisée des systèmes d'information reposant sur Microsoft Active Directory, guide ANSSI-PA-099, version 1.0, octobre 2023.

<https://messervices.cyber.gouv.fr/guides/recommandations-pour-ladministration-securisee-des-si-reposant-sur-ad>

AGENCE NATIONALE DE LA SÉCURITÉ DES SYSTÈMES D'INFORMATION (ANSSI),

Recommandations de sécurité pour l'architecture d'un système de journalisation, guide ANSSI-PA-012, version 2.0, janvier 2022.

<https://messervices.cyber.gouv.fr/guides/recommandations-de-securite-pour-larchitecture-dun-systeme-de-journalisation>

AGENCE NATIONALE DE LA SÉCURITÉ DES SYSTÈMES D'INFORMATION (ANSSI),

Sécuriser la journalisation dans un environnement Microsoft Windows Active Directory, janvier 2022. <https://messervices.cyber.gouv.fr/guides/securiser-la-journalisation-dans-un-environnement-microsoft-active-directory>

JOHNSON A., DEMPSEY K., ROSS R., GUPTA S., BAILEY D., *Guide for Security-Focused*

Configuration Management of Information Systems, NIST Special Publication 800-128, 2011, mise à jour 2019. <https://csrc.nist.gov/pubs/sp/800/128/upd1/final>

MICROSOFT, *Developing a privileged access strategy, Microsoft Learn, mise à jour juin 2024.*

<https://learn.microsoft.com/en-us/security/privileged-access-workstations/privileged-access-strategy>

MICROSOFT, *Use Windows Event Forwarding to assist in intrusion detection, Microsoft*

Learn, mise à jour août 2025. <https://learn.microsoft.com/en-us/windows/security/operating-system-security/device-management/use-windows-event-forwarding-to-assist-in-intrusion-detection>

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST), *Least Privilege,*

Computer Security Resource Center Glossary.

https://csrc.nist.gov/glossary/term/least_privilege

ETNA, *How-to Étape 3 : Critique et analyse, version 2026.02.23, module PRO-ENT5.*

TEIXEIRA T., *PRO-ENT5 - Étape 2 : Missions et projets en lien avec la problématique, 2026.*

TEIXEIRA T., *Rapport d'activités d'alternance - Administration systèmes et réseaux,*

Viaposte, année 2025-2026.

Sources externes consultées le 25 juin 2026.